



Disclaimer: This document is provided for informational and educational purposes only as part of GRC Mastery training course. While we have made reasonable efforts to ensure the accuracy of the information contained herein, it is not intended to be professional advice. We make no warranties or representations of any kind, express or implied, regarding the accuracy or completeness of the information provided. You should not rely on this document for any commercial decision-making. By using this document, you agree to hold us harmless from any and all damages or losses arising from your use of this document.

GRCMastery.com



Data Retention & Disposal Policy

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review



Purpose

This policy ensures that Stark Industries Inc. retains information only as long as necessary for business, legal, or contractual purposes and that all data is securely and permanently disposed of at the end of its lifecycle. This policy is aligned with ISO/IEC 27001:2022 (A.8.10 - A.8.12).

Scope

Applies to all forms of data (digital and physical) handled by Stark Industries Inc. across systems, cloud environments (AWS), developer tools, backups, and employee devices. It includes operational data, logs, code, and any sensitive information processed by or for the company.

Policy Objectives

- Ensure data is retained in line with legal and business requirements
- Prevent unauthorised access to obsolete or unused data
- Ensure secure deletion and disposal of all data and media

Data Retention Policy (A.8.11)

Data Type	Retention Period	Rationale
Source Code	Indefinite	Business continuity and development history
Logs (application, access)	12 months	Incident investigation and compliance
CI/CD Deployment Records	12 months	Audit trails and troubleshooting
Employee Records	7 years	Legal retention requirement (HR)
Vendor Contracts & NDAs	7 years post-expiry	Legal and business continuity
Backup Data	90 days rolling	Recovery from system failure or corruption
Security Incident Records	3 years	Compliance and audit readiness



Customer Support Data	24 months	Service quality assurance
-----------------------	-----------	---------------------------

Data Disposal & Deletion (A.8.10, A.8.12)

1) Digital Media

- Data must be deleted using **secure deletion methods** (e.g. cryptographic wipe, overwrite) before reuse or disposal.
- All cloud storage (e.g. S3, EBS, RDS) must be purged using **provider-supported secure delete options**.
- Backup snapshots are deleted automatically after 90 days via retention policy.

2) Physical Media

- Any physical media (e.g. external drives, printed reports) must be:
 - Shredded or destroyed before disposal
 - Logged if containing sensitive or confidential information

3) Cloud-based Systems

- Ensure data remnants are not left in decommissioned environments
- Revoke associated IAM permissions before termination of systems or instances

Roles and Responsibilities

Role	Responsibility
Data Owners	Define appropriate retention periods and approve deletion
IT/Infrastructure Engineer	Execute secure data disposal and cloud purge procedures
Information Security Manager	Ensure disposal logs and reviews are maintained
GRC Analyst	Verify compliance with policies and audits retention schedules



Exceptions

Any exceptions to this policy must be:

- Documented with a valid justification
- Reviewed and approved by the Information Security Manager

Policy Review

- This policy is reviewed **annually** or upon significant change to the environment or regulatory requirements.